

ENTERPRISE SECURITY ASSESSMENT LAB

S3 PUBLIC / UNAUTHENTICATED ACCESS TESTING

Professional methodology report for S3 anonymous access behaviour testing

Module	Cloud Security Assessment
Document Type	Individual Methodology Report
Phase	Phase 4
Evidence Source	s3-public-bucket-unauthenticated-access.png
Publication Type	GitHub Portfolio - Redacted Lab Version
Prepared For	04-cloud-security/README.md documentation set
File Name	04-s3-public-unauthenticated-access-testing-methodology-report.pdf

1. Executive Purpose

S3 exposure is a common cloud risk. This section documents how unauthenticated access behaviour was tested safely in the lab using AWS CLI and the --no-sign-request option.

2. Scope and Evidence Mapping

Testing objective	Test whether a lab-created S3 bucket allows unauthenticated access and document the observed access behaviour.
Cloud platform	Amazon Web Services (AWS)
Lab context	CloudGoat / authorized vulnerable cloud lab environment
Primary tools	AWS CLI, S3 API, --no-sign-request
Evidence file(s)	s3-public-bucket-unauthenticated-access.png
Result type	S3 public/anonymous access behaviour tested

3. Embedded Evidence Screenshot(s)

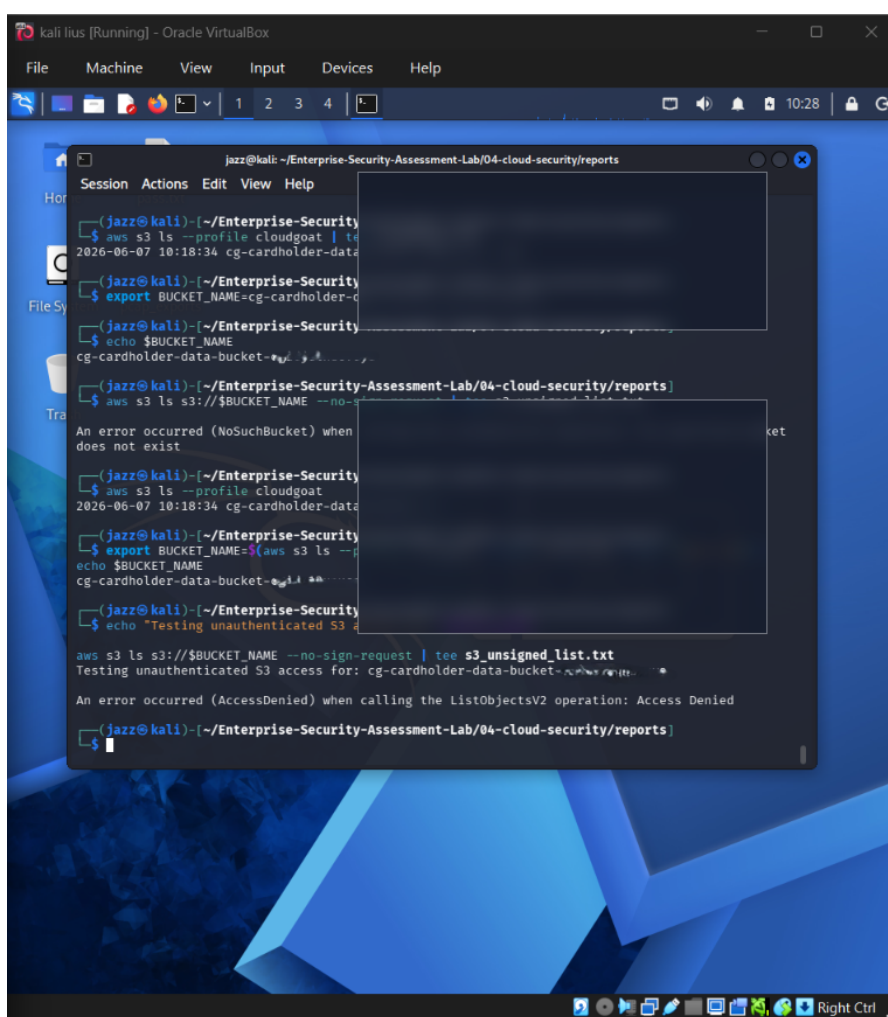


Figure 1 - S3 bucket access behaviour tested with authenticated and unauthenticated commands; bucket names redacted.

4. Methodology and Execution Workflow

The workflow first lists buckets using the authenticated lab profile, then tests bucket listing without credentials. Additional checks review public access block settings and bucket policy status. The result must be described carefully: a successful listing confirms public access; AccessDenied means public listing was not confirmed for that test.

Command / workflow used

```
aws s3 ls --profile $PROFILE
aws s3 ls s3://<REDACTED_BUCKET_NAME> --no-sign-request
aws s3api get-public-access-block --bucket <REDACTED_BUCKET_NAME> --profile $PROFILE
aws s3api get-bucket-policy-status --bucket <REDACTED_BUCKET_NAME> --profile $PROFILE
```

Execution notes

- Use --no-sign-request specifically for anonymous access testing.
- Do not publish bucket names if the bucket still exists.
- Document AccessDenied honestly if public access is not confirmed.
- Review ACLs, bucket policies, and PublicAccessBlock settings together.

5. Sanitized Tool Output Style

The following output example is sanitized. It documents the expected evidence style without exposing AWS account IDs, ARN values, AccessKeyId values, SecretAccessKey values, session tokens, private bucket names, or billing details.

```
Testing unauthenticated S3 access for: <REDACTED_BUCKET_NAME>

aws s3 ls s3://<REDACTED_BUCKET_NAME> --no-sign-request
An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

Interpretation: public listing not confirmed from this command.
```

6. Professional Interpretation

The evidence shows unauthenticated S3 access testing. The screenshot supports that the tester understood how to distinguish authenticated listing from anonymous listing and how to interpret AccessDenied vs public exposure.

7. Risk Analysis

Risk Area	Explanation
Public data exposure	If unauthenticated listing or object retrieval is allowed, backups, logs, application files, or credentials may be exposed.
Bucket policy risk	Principal:* or overly permissive policies can create accidental public exposure.
Reconnaissance risk	Bucket names can reveal project or business context even when access is denied.

8. Defensive Recommendations

- Enable S3 Block Public Access at account and bucket level unless public hosting is explicitly required.
- Review bucket policies and ACLs for Principal:* and public grants.
- Use least privilege bucket policies.
- Enable AWS Config/Security Hub checks for public buckets.
- Monitor unusual GetObject and ListBucket activity.

9. GitHub Redaction and Publication Guidance

Before publishing this document or the underlying screenshot evidence, verify that the following values are removed, blurred, or replaced with placeholders. This is especially important because cloud evidence can contain values that are valid beyond the lab session if not rotated or destroyed.

Sensitive value	Required handling
AWS Account ID	Blur or replace with <REDACTED_ACCOUNT_ID>.
ARN values	Redact account number and private role/user names where needed.
AccessKeyId / SecretAccessKey	Must never be visible. Rotate immediately if exposed.
SessionToken	Must be fully redacted because temporary credentials can still be abused during validity period.
Bucket names / resource names	Redact if they identify private infrastructure or are still active.
Bucket names	Redact if still active or tied to a personal lab account.

10. Evidence Quality Checklist

- The screenshot is readable and aligned within the page margins.
- The evidence filename matches the GitHub link exactly.
- The command/output supports the stated result type.
- No AWS credentials, session tokens, account numbers, or private resource identifiers are visible.
- The report explains both the offensive testing value and the defensive remediation value.